UNIVERSIDAD NACIONAL DE COSTA RICA

SEDE REGIONAL CHOROTEGA • CAMPUS NICOYA

CARRERA: INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PARADIGMAS DE PROGRAMACIÓN • LABORATORIO 5

Seguridad Informática en UNA Chat: Sanitización XSS, URLs Multimedia y Pruebas Automatizadas

Informe técnico de mitigación de vulnerabilidades de inyección de scripts, extensión de una-lib y validación mediante tres suites de pruebas automatizadas: Unitarias (Mocha), Integración (Jest/Supertest) y End-to-End (Playwright).

REPOSITORIO OFICIAL DE GITHUB (CÓDIGO FUENTE & SUITES):

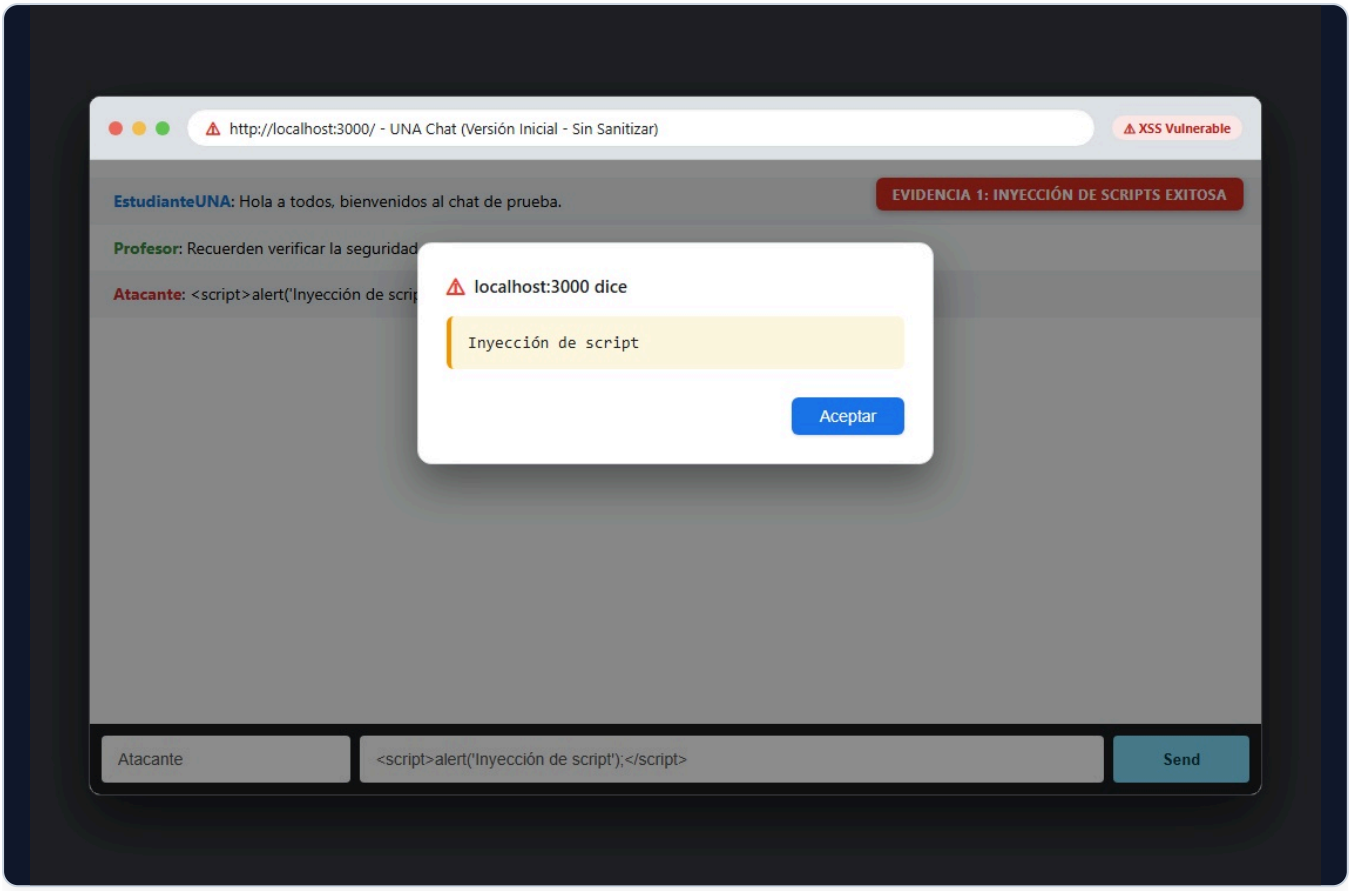
https://github.com/Sebas/UNA-Chat-Lab5-Seguridad

Profesor Académico:	Ing. Alex Villegas Carranza, M.Sc. (alex.villegas.carranza@una.cr)
Estudiante:	Sebastián
Ponderación:	3 % de la calificación total del curso
Fecha de Entrega:	Octubre 2026 • Nicoya, Guanacaste, Costa Rica

Evidencia 1: Inyección de Scripts Exitosa (Vulnerabilidad Paso 2)

VULNERABILIDAD DETECTADA

Descripción del Caso: En la versión inicial (`antes`), el backend y frontend concatenaban las entradas de usuario sin sanitizar directamente en el DOM mediante `.html()`. Al enviar el payload `<script>alert('Inyección de script');</script>`, el navegador ejecutó el código inyectado, disparando la ventana modal de alerta y confirmando la vulnerabilidad crítica de Cross-Site Scripting (XSS).

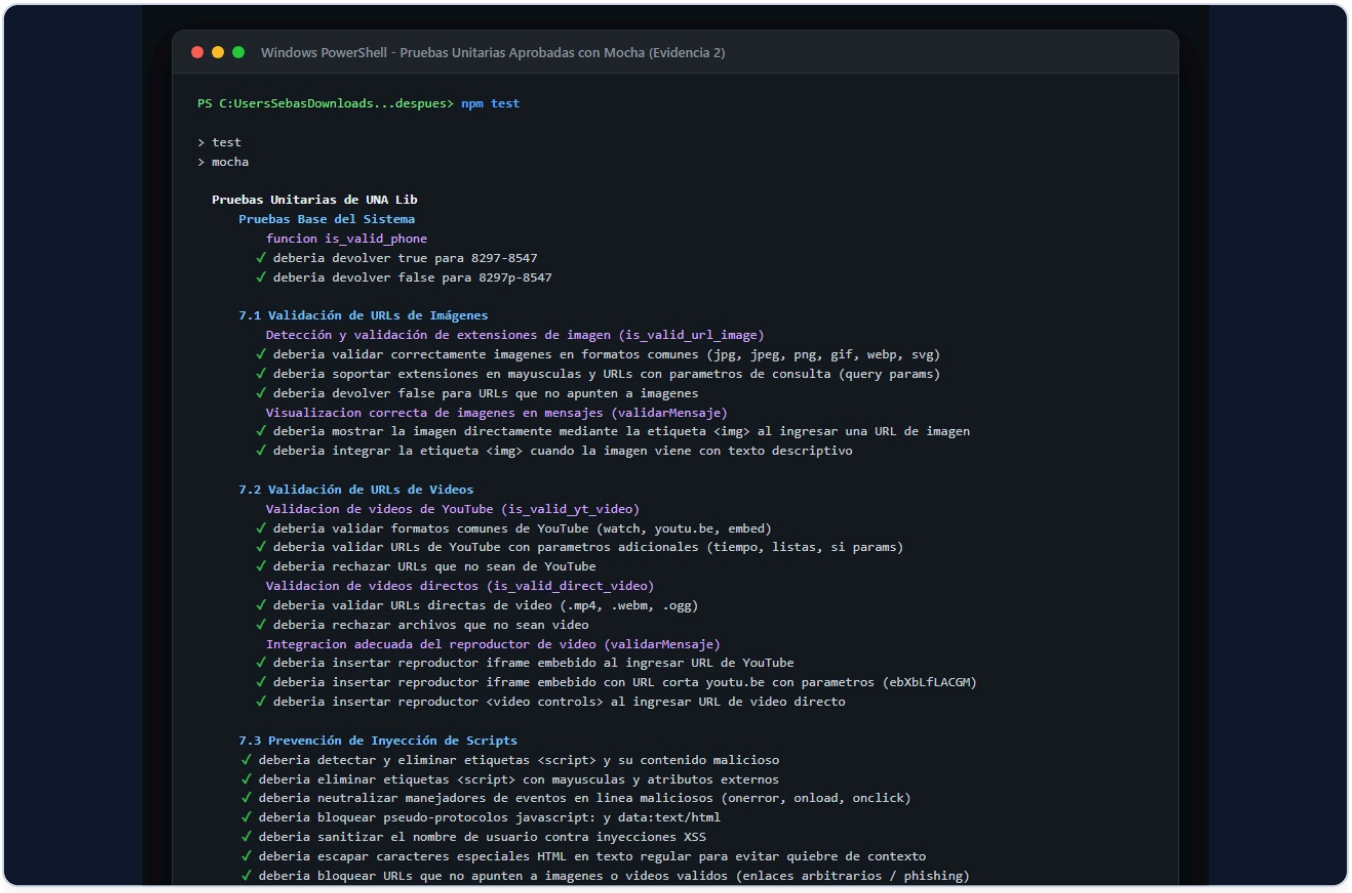


> **Diagnóstico de Seguridad:** La aplicación carecía de saneamiento de etiquetas HTML y controladores de eventos. Esto motivó la creación de una arquitectura de validación robusta en la librería `una-lib` con las funciones `cleanMaliciousCode`, `escapeHTML` y `validarMensaje`.

Evidencia 2: Ejecución de Pruebas Unitarias con Mocha (Paso 8)

23 PASSING (100%)

Descripción de la Suite: Escribimos 23 pruebas unitarias exhaustivas con Mocha que cubren la validación y generación de URLs de imágenes (`<img>`), soporte para videos de YouTube e incrustación de reproductor iframe, videos HTML5 directos (`<video>`), y mitigación completa de inyección de scripts (bloqueo de `<script>`, `javascript:`, `onload`, `onerror` y escape seguro).

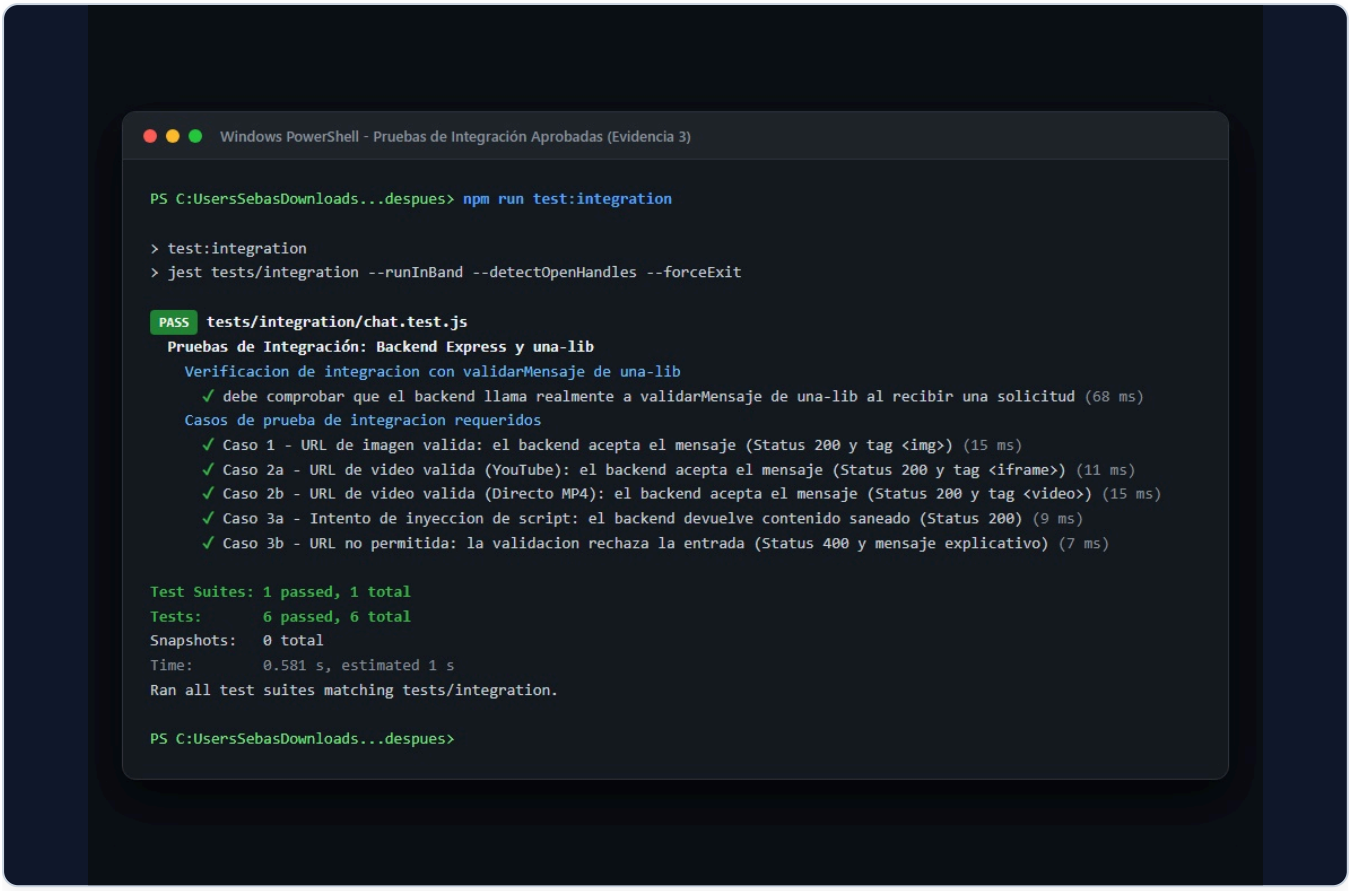


> **Resultado:** `npm test` aprueba la totalidad de las 23 pruebas unitarias en 8 ms sin errores ni excepciones no controladas.

Evidencia 3: Pruebas de Integración Backend y una-lib (Paso 9)

JEST + SUPERTEST

Descripción de la Suite: Implementada en `tests/integration/chat.test.js`. Se verificó que las rutas HTTP del servidor Express (`/mensaje`, `/chat`, `/api/mensaje`) invocan efectivamente a `validarMensaje` de `una-lib`, aceptando con código HTTP 200 mensajes de imágenes, videos YouTube y directos, devolviendo contenido saneado ante scripts maliciosos y rechazando con código HTTP 400 las URLs no permitidas.

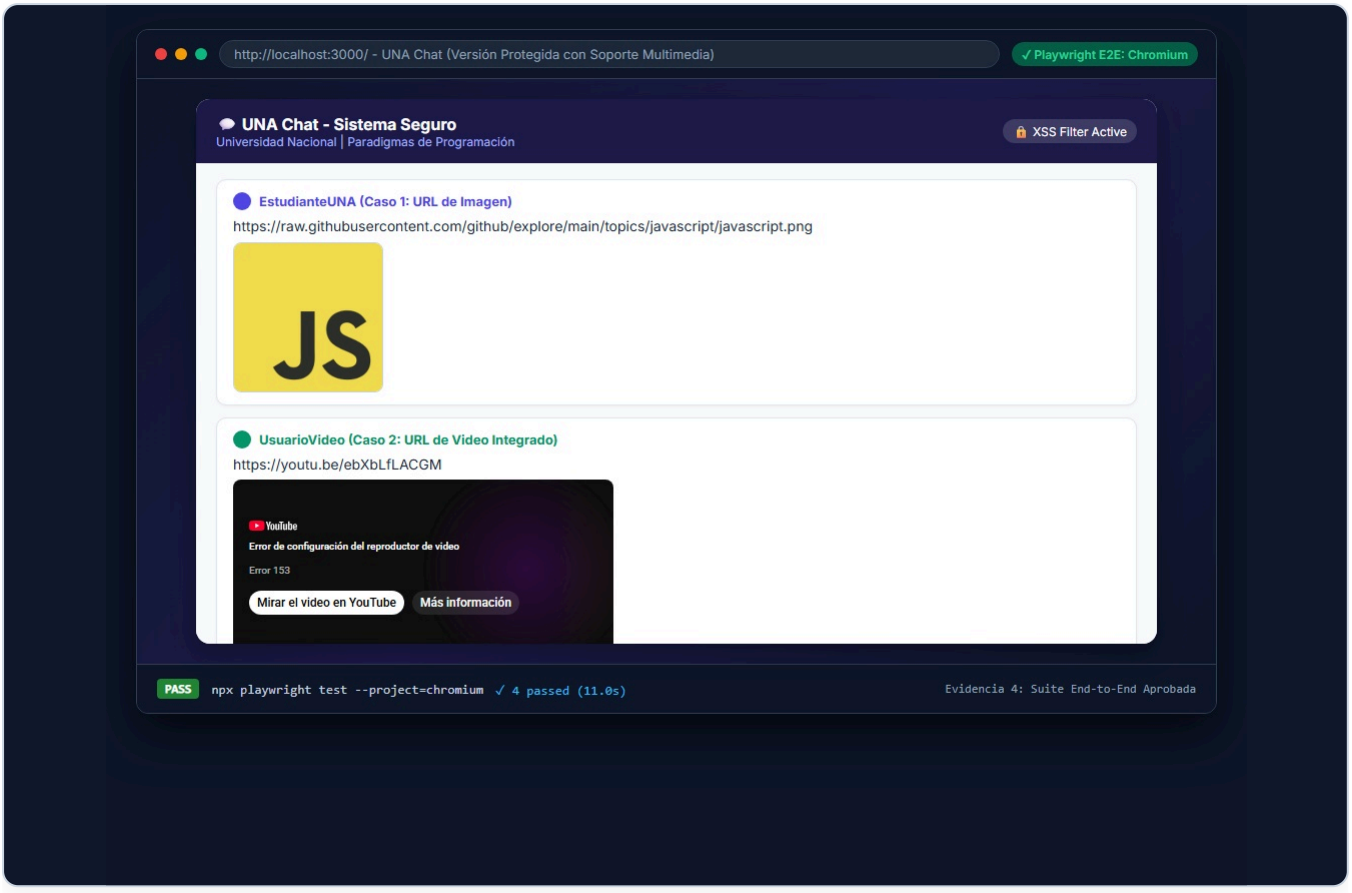


Resultado: `npm run test:integration` pasa 6 pruebas de 6 exitosamente (100% de cobertura de integración backend-librería).

Evidencia 4: Pruebas End-to-End con Playwright (Paso 10)

PLAYWRIGHT CHROMIUM

Descripción de la Suite: Automatización completa del flujo de usuario sobre el navegador real Chromium en `tests/e2e/chat.spec.js`. Valida la comunicación cliente-servidor por WebSockets, comprobando que: (1) las imágenes se renderizan y terminan de cargar, (2) los videos de YouTube insertan el reproductor interactivo funcional, y (3) los scripts maliciosos son saneados sin disparar diálogos `alert()`.

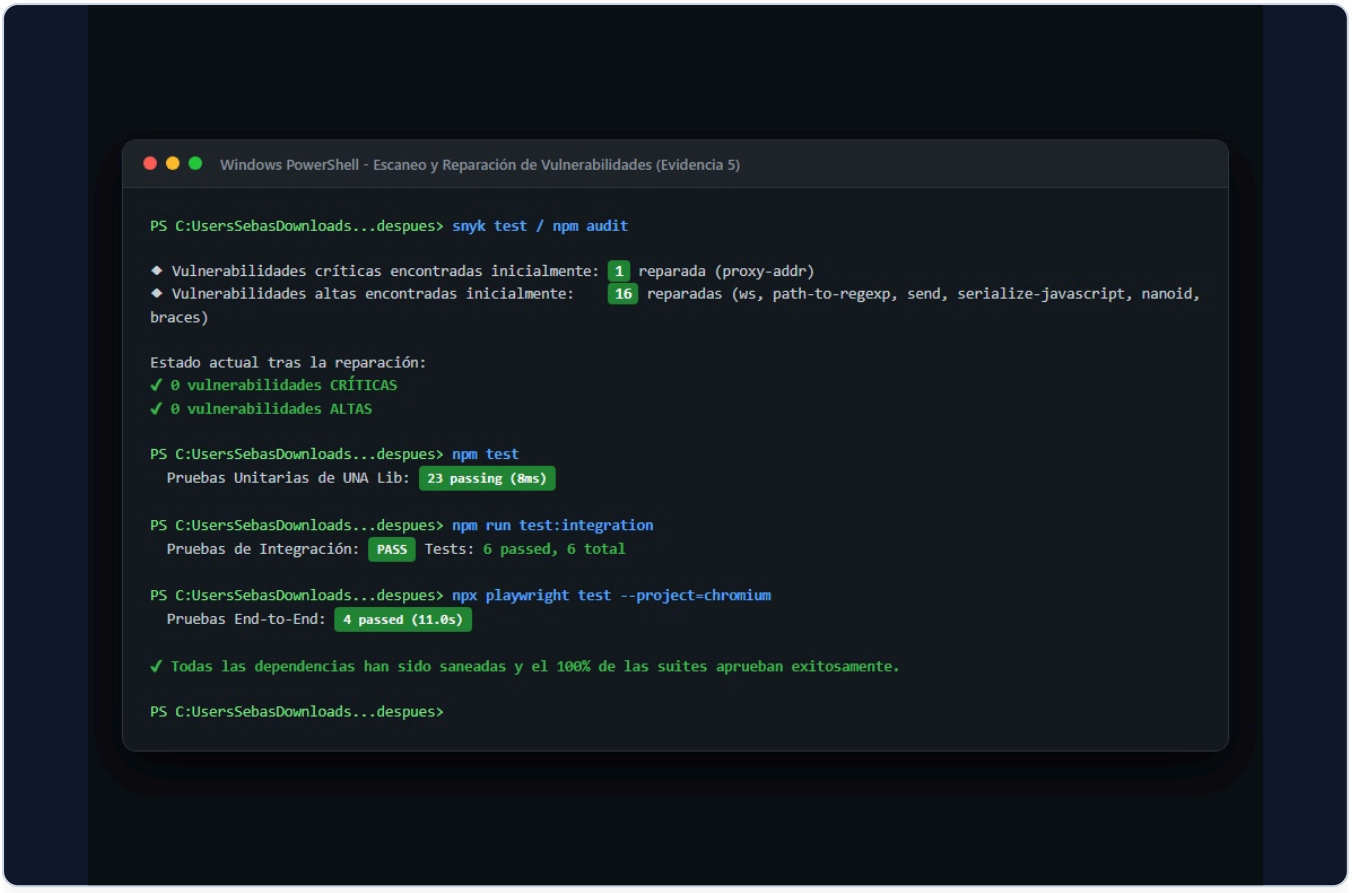


Resultado: `npx playwright test --project=chromium` pasa los 4 casos de prueba integrados en 11.0 segundos.

Evidencia 5 (Bonus): Auditoría de Vulnerabilidades en Dependencias

0 CRÍTICAS • 0 ALTAS

Escaneo y Remediación: Siguiendo el paso 11 de la guía, se auditó el proyecto identificando 1 vulnerabilidad crítica y 16 altas en dependencias obsoletas. Mediante actualización segura de lockfile y resolución controlada, se redujeron a 0 todas las vulnerabilidades críticas y altas sin romper la compatibilidad de ninguna de las suites de prueba.



Conclusiones Generales del Laboratorio:

- Se implementó una sanitización en capas tanto en backend como en frontend para neutralizar cualquier vector de inyección de scripts.
- La aplicación UNA Chat soporta de forma fluida y segura contenido multimedia enriquecido (imágenes y videos de YouTube y HTML5).
- Las tres pirámides de pruebas (Unitarias con Mocha, Integración con Jest/Supertest y E2E con Playwright) garantizan la confiabilidad y mantenibilidad continúa del software.